Cryptography Standard

Group Information Security Standard GIS-STD-07

Document control

Document ID	GIS-STD-07
Title	Cryptography Standard
Version	2.1
Effective date	1 April 2025
Owner	Group CISO (Joost Hendriks), Group Security Office
Approved by	Group Executive Board
Review cycle	Annual
Applies to	All Nordwind Group operating companies (OpCos), their employees, contractors and service providers
Classification	Internal

Revision history

Version	Date	Author	Description of change
1.0	2020-06-01	Group Security Office	Initial release
2.0	2023-10-15	J. Hendriks	Alignment with ISO/IEC 27001:2022; post-quantum watch list added
2.1	2025-03-10	J. Hendriks	Updated TLS requirements; sunset date for AES-128; new clause on telematics (4.3)

1 Purpose

This standard defines the minimum cryptographic requirements for protecting information of the Nordwind Group in transit and at rest. It translates the cryptography control of the Group Information Security Policy into concrete, verifiable requirements.

2 Scope

This standard applies to all information systems operated by or on behalf of Nordwind Group operating companies (OpCos), including on-premises systems (e.g. warehouse management systems), cloud services, mobile devices, vehicle telematics and connections to customers and suppliers. OpCos may define stricter local requirements; they must not define weaker ones.

3 Approved algorithms and key lengths

Only the algorithms listed below may be used for new implementations. Existing implementations that do not comply must be migrated at the next major release or certificate/key renewal, at the latest by the dates stated.

Use case	Approved algorithms	Minimum strength	Prohibited
Symmetric encryption	AES in GCM mode; AES-CBC with HMAC-SHA-256 (legacy systems only)	AES-256. AES-128 is permitted for existing systems until 31 December 2026.	DES, 3DES, RC4, Blowfish, any ECB mode
Asymmetric encryption and key exchange	RSA-OAEP, ECDH (P-256, P-384), X25519	RSA 3072 bit; ECC 256 bit (P-384 preferred)	RSA keys shorter than 3072 bit for new systems; static RSA key exchange
Digital signatures	RSA-PSS, ECDSA, Ed25519	RSA 3072 bit; ECDSA P-256	Signatures based on MD5 or SHA-1
Hashing	SHA-256, SHA-384, SHA-512, SHA-3 family	SHA-256	MD5, SHA-1 (except for non-security checksums)
Password storage	Argon2id, bcrypt, PBKDF2-HMAC-SHA-256	bcrypt cost factor 12; PBKDF2 with at least 600,000 iterations; unique salt per password	Unsalted hashes; reversible encryption of passwords

4 Data in transit

4.1 Transport Layer Security

TLS 1.2 is the minimum permitted protocol version. TLS 1.3 shall be used wherever supported by both endpoints. SSL 2.0, SSL 3.0, TLS 1.0 and TLS 1.1 are prohibited on all systems, including internal systems.

4.2 Data centre interconnects

Traffic between OpCo data centres (e.g. Linz and Wels) and between OpCos and Group data centres shall be encrypted using IPsec or TLS in accordance with section 3.

4.3 Telematics

Communication between vehicle on-board units (OBU) and the telematics platform shall use TLS 1.2 or higher with mutual certificate-based authentication. Where hardware constraints prevent this, a documented exception in accordance with section 8 is required.

4.4 E-mail and file exchange

E-mail transport encryption (STARTTLS) shall be enabled. Attachments classified as Confidential or Strictly Confidential shall be encrypted end-to-end (S/MIME) or exchanged via the approved secure file transfer service.

5 Data at rest

- Full-disk encryption is mandatory on all laptops, tablets (including vehicle tablets) and smartphones that store or access company data.
- Removable media: only company-issued, hardware-encrypted USB devices (AES-256) may be used for Internal, Confidential or Strictly Confidential data.
- Databases containing Confidential or Strictly Confidential data shall be encrypted at rest.
- Backups shall be encrypted with AES-256; encryption keys shall be stored separately from the backup media.

6 Key management

6.1 Generation and storage

Cryptographic keys shall be generated and stored in an approved hardware security module (HSM) or an approved key management service (KMS). Keys must never be hard-coded in source code, scripts or configuration files in plain text.

6.2 Rotation

Symmetric data encryption keys shall be rotated at least every 12 months and immediately upon suspected compromise. Key encryption keys (master keys) shall be rotated at least every 24 months under dual control.

6.3 Certificates

Internal certificates are issued exclusively by the Group PKI. The maximum validity of internal certificates is 2 years. Private keys shall be marked non-exportable where technically possible.

6.4 Key custodians and destruction

For every system using encryption, a key custodian shall be named. The destruction of keys shall be documented.

7 Post-quantum readiness

Each OpCo maintains a cryptographic inventory of its systems and submits an updated inventory to the Group Security Office by 31 January each year.

8 Exceptions

Deviations from this standard require a documented risk assessment, compensating controls and written approval by the **Group CISO**. Exceptions are limited to a maximum duration of 12 months and are recorded in the Group Exception Register. Local information security officers (ISB) may support the request but may not approve exceptions to this standard.

9 Compliance

Compliance with this standard is verified through internal audits and technical scans. Non-compliance is reported to the Group Risk Committee.

10 Definitions

Term	Definition
CMK	Customer-managed key – a key controlled by Nordwind in a cloud KMS
HSM	Hardware security module

Term	Definition
KMS	Key management service
OBU	On-board unit – telematics device installed in a vehicle
OpCo	Operating company of the Nordwind Group, e.g. Nordwind Logistics GmbH (AT)